



THE KENYATTA UNIVERSITY TEACHING, REFERRAL & RESEARCH HOSPITAL (KUTRRH)

INFORMATION COMMUNICATION TECHNOLOGY POLICY AND MANUAL



DOCUMENT DESCRIPTION

Status	Active
Reference Number	KUTRRH/ICT/POL/01
Title	ICT POLICY
Type	Policy
Version	1/0
Active Date	June 2021
Reviewed	May 2021
Next Review Date	June 2024
Accessed by	All Staff
Availability	Soft Copies
Custodian	Deputy Director, ICT & INNOVATION

APPROVAL

Action	Title	Name	Signature
Author	DD ICT & Innovation	Dr. Mwirigi Kiula	
Reviewed by	Quality Assurance Manager	Daniel Kimondo	
	Chief Executive Officer	Dr. Victor Njom	
Approved by	Chairperson of the Board	Prof. Olive Mugenda, PhD, EBS, CBS	



Table of Contents

FOREWARD	V
PREFACE	VI
DEFINITIONS	VII
Vision	VII
Mission	VII
Values	VII
Objectives of the KUTRRH	VIII
Purpose of the KUTRRH ICT Policy	VIII
1. INTRODUCTION	1
2. ICT POLICY OBJECTIVES	1
3. PRINCIPLES	1
3.1 Segregation of Duty	1
3.2 Subsidiarity	1
3.3 Equivalence	2
3.4 Continual improvement	2
3.5 Redundancy	2
4. DIGITAL TRANSFORMATION AGENDA	2
4.1 The 4-Point Digital Transformation Agenda	2
4.2 The Strategies	3
4.3 Corporate Ownership and Implementation	4
4.4 Monitoring, Evaluation and Review of the Digital Strategy	5
5. ROLES AND RESPONSIBILITIES	5
5.1 Board of Directors	5
5.2 Chief Executive Officer	5
5.3 Executive and Senior Management Team	5
5.4 User Managers	5
5.5 Users	5
5.6 ICT Department	6
6. CONTROLS	6
6.1 How Information Security is Organized	6
6.2 Human Resources Security	7
6.3 Asset Management	9
6.4 Access Controls and Managing User Access	11
6.5 Cryptographic Technology	15
6.6 Physical Security of KUTRRH's Sites and Equipment	17
6.7 Operational Security	19
6.8 Secure Communications and Data Transfer	19
6.8.5 Sender's Responsibility	22
6.9 Secure Acquisition, Development, and Support of Information Infrastructure	22
6.10 Security for Suppliers and Third Parties	23
6.11 Incident Management	24
6.12 Business Continuity/Disaster Recovery	25
6.13 Compliance	28
6.14 E-Waste Management	28
6.15 Telemedicine	29

7.LEADERSHIP AND GOVERNANCE FRAMEWORK31

7.1 Ownership31

7.2 The Organizational Structure32

8. POLICY IMPLEMENTATION, MONITORING, EVALUATION AND REPORTING32

9. REVIEW32



FOREWARD

Kenyatta University Teaching, Referral and Research Hospital vision is to be a premier National Referral Hospital renowned for clinical excellence, medical training and research that enhances quality of lives for Kenyans and the regional citizens. The accomplishment of this vision rests on the deployment of appropriate state of the art technology and digital transformation.

The Board of Directors seeks to establish the right ICT leadership and governance supported by sound policies, standards, procedures, and practices to ensure that KUTRRH can live to the fullness of its mandates, remains steady and sustainable and facilitates the fulfilment of the aspirations of the public, the nation, and the region.

The KUTRRH ICT Policy provides beacons in the application of digital tools and digital transformation in the teaching, research, and referral hospital domains and to fulfill its vision, mission, and objectives, advance its values and promote quality patient centered care for the common good of the Republic of Kenya and the world at large.

Prof. Olive Mugenda, Ph.D., EBS, CBS
CHAIRPERSON, BOARD OF DIRECTORS



PREFACE

Kenyatta University Teaching, Referral and Research Hospital sets out to provide patient centred and evidence-based health care, training, innovation, and state of the art technology. This mission requires a robust ICT infrastructure, systems, information security, services, standards, policy, and practice environment.

This ICT Policy outlines the requirements for installation, implementation, configuration, utilization, administration, support and maintenance, security, training, continual improvement and granting access to ICT infrastructure, systems, and services. The scope of the policy covers all information infrastructure, staff, contractors and third parties.

The heart of the Policy is to support the digital transformation of KUTRRH in the provision teaching, research, referral and quality patient centred care services, evidence-based health care and evidence-based decision-making. The staff, partners and contractors are committed to the implementation of the Policy in the spirit of the vision, mission, and core values of KUTRRH.

Dr. Victor Njom
Ag. CHIEF EXECUTIVE OFFICER



DEFINITIONS

Vision

To be a premier National Referral Hospital renowned for clinical excellence, medical training and research that enhances quality of lives for Kenyans and the regional citizens.

Mission

To enhance quality of lives through provision of patient-centered and evidence-based health care, training, innovation, and state of the art technology.

Values

Work ethics and integrity

Efficiency and teamwork

Care and compassion

Accountability

Respect

Equity



Objectives of the KUTRRH

The objectives of KUTRRH are:

1. To provide national and regional referral hospital services renowned for clinical excellence.
2. To provide quality patient-centered and evidence-based health care.
3. To reinforce medical training and research.
4. To drive medical innovation and entrepreneurship.

Purpose of the KUTRRH ICT Policy

The purpose of the KUTRRH ICT Policy is to enable the teaching, referral, and research hospital to fulfill its vision, mission, and objectives, advance its values and promote quality patient centered care for the common good of the Republic of Kenya and the world at large. This policy outlines the requirements for installation, implementation, configuration, utilization, administration, support and maintenance, security, training, continual improvement and granting access to ICT infrastructure, systems, and services. The heart of the Policy is to support the digital transformation of KUTRRH in the teaching, research, referral, and quality patient centered care.



1. INTRODUCTION

This ICT Policy therefore covers important issues including digital transformation strategy, information security, human resource security, asset management, access control, encryption, physical security, operational security, secure communications, secure acquisition and development of ICT assets, security of third-parties, incident management, business continuity and disaster recovery as well as e-waste management.

2. ICT POLICY OBJECTIVES

The following are the objectives of the KUTRRH ICT Policy:

1. To guarantee effective and efficient ICT infrastructure, systems, and services. Operations and management to support effective and efficient provision of patient-centered and evidence-based health care, training, research and innovation;
2. To ensure the continuity of systems processing services;
3. To protect information resources from unauthorized access;
4. To guarantee the privacy and accuracy of information resources;
5. To prevent and detect possible threats, violations, and security incidents;
6. To facilitate proper restoration of the functionality of damaged resources;
7. To provide reference point on particular and general issues regarding information assets, safe and secure use, sound and legal use, operations, and management.

3. PRINCIPLES

The ICT Policy is informed by the following principles.

3.1 Segregation of Duty

The principle of segregation of duty is based on shared responsibilities of a key process that disperses the critical functions of that process to more than one person or department. It is an important part of protecting company assets such as money, inventory, patient, staff data, client and partner data, research data and financial data and/or information. It holds that no single staff should carry out a process single-handedly from initiation to closure.

3.2 Subsidiarity

Subsidiarity is an organizing principle that ought to be handled by the smallest, lowest, or least centralized competent authority. The principle holds that a central authority should have a subsidiary function, performing only those tasks which cannot be performed at a more local level. Actions should be fulfilled by the lowest level possible such as capturing of patient data or diagnosis records into the HMIS by a medical records officer or the doctor who handled the patient.

3.3 Equivalence

Paper documents and their electronic counterparts have the same legal value. The principle holds that the paper document and the electronic counterpart in the automated systems of KUTRRH are equal and interchangeable. A document generated from the HMIS or any other system and stored in the physical archives of the KUTRRH has the same weight as the original record stored in the electronic backups of the HMIS of the same document.

3.4 Continual improvement

The ICT infrastructure, systems and services are dynamic just as the prevailing national and global environment. There are internal and external changes that impact operations, business processes, management, and decision-making. This calls for ongoing effort to improve on the quality of care, clinical and nursing services, processes, products as well as the ICT infrastructure, systems, services standards, and policies.

3.5 Redundancy

Redundancy is the duplication of critical components or functions of a system with the intention of increasing reliability of the system, usually in the form of a backup or fail-safe, disaster recovery or improvement of actual system performance. System reliability is improved through redundant or backup components. The reliability of KUTRRH operations and management shall be gradually and continually improved through adoption of redundancy of critical components of ICT infrastructure, systems, and services as well as continual improvement of the performance of the key systems including the HMIS.

4. DIGITAL TRANSFORMATION AGENDA

The digital transformation agenda of KUTRRH is based on a 4-point agenda founded on the transformation of citizen experience, stable systems and operations, visibility, and digital innovation.

4.1 The 4-Point Digital Transformation Agenda

4.1.1 Citizen Experience

A premium is placed on citizen experience. Planning, executing, monitoring, evaluation, and digital innovation will focus on the improvement of citizen experiences including patients and their close communities; the staff and their close relatives; partners, collaborators, and co-actors.

4.1.2 Stable Systems and Operations

Stable systems are pivotal in the excellence of KUTRRH. Capacity will be built around stable information infrastructure including hardware and networks; systems and applications software; data and data management; digital tools; people and processes; and standards and policies to support efficiency, teamwork, accountability, and delighted citizens.

4.1.3 Visibility

The operations of KUTRRH need to be visible with respect to data, information, analytics, reports, knowledge and insight to the management and the Board of Directors. This visibility is expected to enhance evidence-based health care and evidence-based decision making with clear, correct, and integrated information across functions and at all levels subject to authority and responsibility.

4.1.4 Digital Innovation

Innovation is inseparable with digital transformation. The information division will spur, develop, and roll out digital solutions while supporting the clinical, training, research, innovation, administrative and corporate services. It will also support innovation and entrepreneurship for KUTRRH, the nation and the world.

4.2 The Strategies

KUTRRH will implement the following strategies to accomplish the digital transformation of KUTRRH:

4.2.1 Diversification and deployment of agile service channels

The number of service channels for institutional critical services including pre-admission engagement, registration, consultation, patient tracking, continued patient engagement will be diversified to include:

- 1) Management of scheduled appointments.
- 2) Online and walk-in instant registration and other related services.
- 3) Introduction of apps and portals for patients, staff, citizens, and partners.
- 4) Introduction of credit card, mobile other electronic fees payments.
- 5) End-to-end progression application solution to manage patients from pre-engagement to post-hospitalization relationship as well as staff, trainees, and partners from recruitment to exit.
- 6) Deployment of a customer care center to provide 24-hour customer support/care and supplement instant issue capture, handling, and tracking.

4.2.2 Seamless integration of infrastructure, systems, and services

The infrastructure, systems and services in place and planned to be in place will be integrated to facilitate one single point of contact with data, information, and services on KUTRRH including:

- 1) Information infrastructure
 - a) Data Centre (primary and secondary)
 - b) Core network with value-added services and ride-on services
 - c) IP Telephony
 - d) Intelligent surveillance
 - e) Access control
 - f) Managed Wi-Fi services
 - g) Presentation facilities (with integrated audio-visual services)
- 2) Application solutions
 - a) Fully integrated Hospital Management Information System managing the patient journey,



- human resources, financials, procurement, logistics and training, research, and innovation.
- b) Enterprise volume licenses for critical solutions including and not limited to productivity tools (office tools), security (anti-virus) and related subscriptions.
 - c) Adoption of open-source tools where possible.
 - d) Full integration of all applications and tools including intelligence surveillance and biometrics.

4.2.3 Smart Implementation, financing, and management

KUTRRH will adopt smart implementation approaches to ensure quicker returns and longer-term payment plans to ensure effective solutions with easier cash-flow burdens with the adoption of:

- 1) Turn-key solutions and end-to-end solutions.
- 2) Gravitation towards managed services and/or leased services.
- 3) Utilization of diverse financing options such as supplier financing.
- 4) Electronic insurance policies for core infrastructure.
- 5) Adoption of low cost/open-source customizable solutions for extensions of service from the core systems and services.
- 6) Use of community/membership services for critical services such as the Kenya Education Network (KENET), the national research and education network of the Republic of Kenya for broadband infrastructure, bandwidth, research data connectivity, e-research infrastructure, collocation, business continuity and disaster recovery as well as skilled ICT capacity building.

4.2.4 Engagement of people, process, technology, and service quality

KUTRRH will deploy smarter planning around people, process, technology, and service in the roll-out of new solutions and services including:

- 1) Engagement of technical and legitimate drive channels to develop and/or deploy solutions.
- 2) Orientation based on the role of technology for enhanced productivity.
- 3) Facilitated and standardized Bring Your Own Device/Network (BYOD/N) for staff, contractors, and partners.
- 4) Benchmarking with best practices in digital service management.

4.2.5 Risk-Based Investment in ICT Infrastructure, Systems and Services

KUTRRH will deploy smarter planning around technology risks with heightened cybersecurity and dependence on technology in the roll-out of new solutions and services including:

- 1) Embedding redundancy in the deployment of network and systems.
 - a) Lit fiber to Gatundu Level 5 Hospital in liaison with KENET and the Government of Kenya data connectivity.
 - b) Redundant core network to buildings and facilities within KUTRRH and affiliates.
 - c) Automated regular back-ups with best practices on tests and restoration procedures.
- 2) Acquisition/implementation of secondary data center services.
 - a) Use of cloud-based backup or collocation services in the short run.
 - b) Secondary data center hot site at Tier III or IV in the long run.

4.3 Corporate Ownership and Implementation

The implementation of the flagship projects shall be a corporate responsibility of the Board of Directors, Chief Executive Officer, the Directors, Deputy Directors, Heads of Departments, the Staff with the orchestration of the Deputy Director, ICT & Innovations.

4.4 Monitoring, Evaluation and Review of the Digital Strategy

The implementation of the digital strategy will be monitored based on project plans for the respective flagship projects, evaluated quarterly and reviewed annually for efficiency and efficacy.

5. ROLES AND RESPONSIBILITIES

5.1 Board of Directors

The Board of Directors shall provide the strategic leadership, governance, and direction of KUTRRH including and not limited to the digital transformation and responsiveness to the dynamic operating internal and external environment.

5.2 Chief Executive Officer

The Chief Executive Officer is the owner of all ICT infrastructure, systems, processes, operations, services, policies, and standards. This includes and not limited to the provision of strategic leadership and governance, planning, budgeting, implementation, oversight, evaluation, continual improvement, and liaison with the Board of Directors.

5.3 Executive and Senior Management Team

The Executive, the Senior Management Team and the Deputy Director, ICT & Innovation are ultimately responsible and accountable for corporate governance on ICT infrastructure, systems, services, standards, and policies. The Executive and the Senior Management Team shall provide the overall strategic direction by approving and mandating the principles and standards delegating operational responsibility for conceptualization, planning, resourcing, implementation, deployment, support and maintenance and the continual improvement of the KUTRRH digital environment.

5.4 User Managers

User managers are KUTRRH staff who authorize information access based on a job description. If a job description does not exist, the user manager is responsible for creating the description. In addition, obtaining the approval of relevant owners. User managers shall:

1. Be responsible for the activities of staff, consultants and temporary assistants authorized to gain access to KUTRRH's information systems under their written approval.
2. Maintain different classification levels of information depending on access right matrix.
3. Be responsible for promptly changing user access privileges accordingly. User-IDs are specific to individuals and shall not be reassigned or shared.

5.5 Users

An information user is any person who has been authorized to access KUTRRH's information resources. User access is based on a user's job profile and is granted by a user manager. Users shall be:

1. Assigned user-IDs to gain access to information systems.

2. Required to familiarize themselves and act in accordance with all KUTRRH's information security procedures.
3. Required to participate in information security training and awareness sessions and report any suspicious activity or security problem.

Users also include persons living with disabilities such as visually impaired and otherwise print disabled persons.

Continual improvement ICT infrastructure, systems, services, and standards will be done gradually to address access, use roles and responsibilities for this category of users.

5.6 ICT Department

The ICT Department is responsible for all ICT infrastructure, systems and services, policies, standards and processes for the digital transformation and continual improvement of the Hospital's digital technology and digital capability. The ICT Department shall:

1. Make recommendations to senior management, considering the needs of various owners, managers, custodians and users on ICT infrastructure, systems, and services.
2. Upon management approval, implement information security standards, procedures, and policies.
3. Be responsible for coordinating all activities related to administration of access control, monitoring the security of KUTRRH's information systems, and providing information security training.
4. Carry out regular security control and provide management with reports on the current state of information security within the KUTRRH.
5. Be responsible for organizing a Computer Emergency Response Team (CERT) to respond promptly to security issues, such as virus-based infections and break-ins.

6. CONTROLS

The Hospital shall implement controls to ensure the effective development and continual improvement of ICT infrastructure, systems, services, and standards. The controls will be based on the standard information security controls.

6.1 How Information Security is Organized

Information security activities shall be coordinated throughout KUTRRH to ensure consistent

application of the security principles, standards, and policy statements. The ICT Department shall provide the continued and regular implementation, monitoring and evaluation of the ICT Policy in coordination with the other departments of KUTRRH. The provisions of the Policy account for the collaborative role of the users, user managers and departments.

6.2 Human Resources Security

People within the organization are a potential source of either an accidental or a malicious threat. They can also be very effective information security controls if trained properly and made aware of their responsibilities and the risks relevant to their job role. KUTRRH employees, contractors and other third parties are expected to play a key role in information security - in securing the ICT infrastructure, systems, and services and to protect against undermining the security. The Human Resource Department shall be responsible for the implementation of the human resource security requirements pre, in and post-employment.

6.2.1 Pre-Employment

All potential employees (part-time, casual, contract, permanent, visiting, residency and internship/attachment) and contractors shall be required to furnish KUTRRH with:

1. Certificates of good conduct from the authorized agent of the Government of the Republic of Kenya.
2. Complete biodata and complete curriculum vitae for all potential employees.
3. Clearance from Higher Education Loans Board, Tax Compliance Certificate, Credit Reference Bureau and other leadership and integrity requirements.
4. Every employee may be subjected to additional background checks and formal pre-employment screening.

6.2.2 In-Employment

6.2.2.1 Management Responsibility

Every employee shall be expected to understand and implement the requirements of this Policy.

Management responsibilities shall include ensuring that employees and contractors are:

1. Properly briefed on their information security roles and responsibilities prior to being granted access to confidential information or information systems.
2. Provided with guidelines to state information security 'expectations of their role within the organization.
3. Motivated to fulfil the information security policies of KUTRRH.
4. Achieve a level of awareness on information security relevant to their roles and responsibilities within the organization.
5. Read, understand, and conform to the terms and conditions of employment, which includes the organization's information security policy and appropriate methods of working.
6. Continue to have the appropriate skills and qualifications and are educated on a regular basis.

Management should demonstrate support of information security policies, procedures and controls, and act as a role model.

The Human Resource Department shall communicate expeditiously to the ICT Department at the onboarding of new employees.

6.2.2.2 Employee Responsibility

7. It is the responsibility of each and every employee to ensure confidentiality, integrity, availability and auditability of every activity, data and/or information generated in the course of duty.
8. It is the responsibility to safeguard the vision, mission, objectives, and core values of the Hospital.
9. It is the responsibility of each, and every employee to report any incidence and take actions to mitigate the effects of the incidence on the Hospital, employees, patients, systems, and services.

6.2.2.3 Tele-Working/Tele-Commuting

1. An employee may only tele-work/tele-commute on approval of the respective Head of Department or authorized officer of the Hospital and subject to the Hospital policies and standard operating procedures.
2. Employee off-premise access to KUTRRH restricted ICT infrastructure, systems and services including the HMIS shall be done through VPN (Virtual Private Network) and only on appropriately secured computing device.
3. The employee shall present to the ICT Department the computing devices for purposes of tele-working/tele-commuting for configuration and testing.
4. Employee access to restricted ICT infrastructure, systems, and services from KUTRRH premises shall be through VPN subject to perimeter security (firewall) and access rights for the respective authorized staff.
5. It is the responsibility of every employee to ensure confidentiality, integrity, availability and auditability of every activity, data and/or information generated in every tele-working/tele-commuting environment.

6.2.2.4 Bring Your Own Device/Network

1. An employee may utilize their own devices to carry out Hospital work subject to the Hospital policies and standard operating procedures.
2. Every employee shall ensure confidentiality, integrity, availability and auditability of every activity, data and/or information generated in every BYOD/N environment.
3. The Hospital Management may restrict the standards of devices and software to safeguard the Hospital, employees, patients, systems, and services.

6.2.3 Post-Employment

To protect the organization's interests as part of the process of changing or terminating employment, information security responsibilities and duties that remain valid after termination or change of employment shall be defined, communicated to the employee or contractor, and

enforced.

Access rights to information and information systems shall be removed upon termination of the employment or contractual relationship. KUTRRH must have an established and logged procedure for the withdrawal and/or modification of access rights for departing employees, contractors, and third-party users.

Control includes:

1. Changes of employment or contractual status include removal of all rights associated with prior roles and duties, and creation of rights appropriate to the new roles and duties;
2. Removal or reduction or enhancement of access rights prior to the termination, where risks indicate this step to be appropriate (e.g., where termination is initiated by the organization, or the access rights involved highly sensitive information or facilities).
3. Expeditious communication by the Human Resource Department on the end of employment.

6.2.4 Management Responsibility

The user managers (including and not limited to Directors, Deputy Directors, Heads of Departments) in conjunction with the Human Resource Manager shall play a critical role in ensuring security consciousness and conscientiousness throughout KUTRRH and in developing an appropriate “security culture”. They shall, among others:

1. Ensure that roles and responsibilities of each staff under them are spelt out clearly and communicated to the Deputy Director, ICT & Innovation for configuration of access rights into the HMIS and other ICT infrastructure, systems, and services at the point of reporting for new staff, job changes for existing staff and termination of rights for exiting staff;
2. Ensure that all employees and, where relevant, contractors receive appropriate awareness, education and training and regular updates in organizational policies and procedures, as relevant for their job function;
3. Ensure that those they are responsible for understand the information security threats, vulnerabilities and controls relevant to their job roles;
4. Ensure buy-in to proactive and adequate support for relevant information security policies and controls; and
5. Reinforce the requirements of the terms and conditions of employment.

6.2.5 Disciplinary Matters

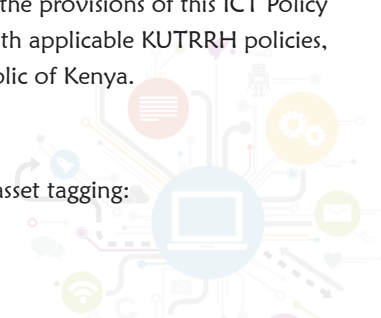
Staff and third parties who, by commission or omission, breach the provisions of this ICT Policy are subject to sanctions and disciplinary action in accordance with applicable KUTRRH policies, statutes, codes, rules and regulations, and the laws of the Republic of Kenya.

6.3 Asset Management

6.3.1 Asset Types

The following minimal asset classes are subject to tracking and asset tagging:

- a. Desktop workstations
- b. Laptop mobile computers
- c. Tablet devices



- d. Printers, copiers, fax machines, and multifunction print devices
- e. Handheld devices (e.g., phones, pagers, transcribing machines)
- f. Scanners
- g. Servers
- h. Network appliances (e.g., firewalls, routers, switches, Uninterruptible Power Supplies (UPS), endpoint network hardware, and storage)
- i. Private Branch Exchange (PBX) and Voice over Internet Protocol (VOIP) Telephony Systems and Components.
- j. All general electronic equipment or devices including and not limited to Internet of Things (IoT).

6.3.2 Asset Value and Tracking

- a. All assets, regardless of value, shall be tracked.
- b. Assets, which store data, shall be tracked either as part of a computing device or as a part of network attached storage. These assets include:
 - i. Network Attached Storage (NAS), Storage Area Network (SAN) or other computer data storage
 - ii. Temporary storage drives
 - iii. Tape or optical media with data stored on them including system backup data
- c. The Finance Department shall put in place mechanisms for asset valuation, depreciation, and reporting.
- d. The Procurement Department shall put in place mechanisms for asset disposal.
- e. The ICT Department shall put in place mechanisms for the protection of data/information in ICT assets due for disposal.

6.3.3 Asset Tracking Requirements

The following procedures and protocols apply to asset management activities:

- 1. All assets must have an internal asset number assigned and mapped to the device's serial number and or the MAC address.
- 2. An asset-tracking database shall be created to track assets. It shall minimally include purchase and device information including:
 - a. Date of purchase
 - b. Make, model, and descriptor
 - c. Serial Number and or the MAC Address
 - d. Location
 - e. Type of asset
 - f. Owner
 - g. Department
 - h. Purchase Order number
 - i. Disposition

3. Prior to deployment, Asset Management Section of the Finance Department shall assign an ID to the asset and enter its information in the asset-tracking database. All assets maintained in the asset tracking database inventory shall have an assigned owner.
4. When disposing of any ICT assets, sensitive data must be removed prior to disposal. The Information Security Department of the ICT Department shall determine what type of data destruction protocol should be used for erasure. Minimally, data shall be removed using low level formatting and degaussing techniques. For media storing confidential or patient/staff/partner personally identifiable information (PII) that is not being repurposed, disks shall be physically destroyed prior to disposal.
5. Any loss of an ICT Asset shall be reported within 24 hours through the toll-free line 1558 or customercare@kutrrh.go.ke or the KUTRRH self-service portal. KUTRRH reserves the right and course of action in recovery of the asset and asset value.

6.3.4 Return of ICT Assets

1. All employees, contractors and third parties shall return all the KUTRRH assets in their possession upon termination of the employment relationship or contract. Assets includes all instances of information, data, documents, laptops, computers, etc. The clearance checklists shall include an ICT clearance section.
2. Procedures and processes to transfer official information contained on personal devices such as home computers and mobile devices to agency owned information assets shall be established.

6.3.5 Shelf Life

1. The shelf life for laptops and tablets shall be 4-7 to years, desktop computers 5-8 years and handheld devices 2-4 years.
2. Support and maintenance shall be an integral part of the acquisition, use and life of the ICT assets. This shall include regular support and maintenance activities by the ICT Department and the facilities management office, service level agreements for hardware and software and managed leases.
3. The staff allocated a laptop, tablet or handheld device may take over ownership at 5 years for a laptop or tablet and 3 years for a handheld device upon payment of the residual value.
4. KUTRRH shall endeavor to generate maximum value from ICT assets. Replacements may be done at 6 years for laptops, 7 years for desktop computers and 3 years for handheld devices.

6.4 Access Controls and Managing User Access

6.4.1 General

Staff, consultants, heads of sections and departments, contracted service providers, deputy directors, Directors and CEO may be provided access to the systems needed to perform the functions of their positions as governed by the following guidelines:

1. Staff, consultants, heads of sections and departments, contracted service providers, deputy directors, Directors and CEO directly responsible for maintaining or utilizing banner data may be eligible for an account.

2. Additional consideration may be granted for other employees with supervisor and data custodian approval.
3. The staff, heads of sections, heads of departments, Deputy Directors, Directors, contracted service providers must have a current contract/formal engagement with KUTRRH.
4. Only staff with KUTRRH email accounts shall be granted access.
5. Requests for access (new or existing users) shall be, upon approval by the respective User Manager, sent to ICT Department and the account will be created or modified.
6. When a staff is moved from his/her position to a different position the previous rights shall be deactivated, and new rights be activated based on the new roles and responsibilities. All staff redeployment by the Human Resource Department or any reassignment within departments (e.g., Finance, Procurement) shall be notified to the Deputy Director, ICT & Innovation with immediate effect for modifications of access rights.
7. The access rights for staff/partner or contracted service providers shall be configured to expire at the end of the engagement. This shall apply to any other category of staff whose engagement is limited to a specific duration. Patient/alumni/citizen interaction with KUTRRH through the health apps (among others) may be for an unlimited time.

6.4.2 Off-Premise Access

4. Off-premise access is only offered to currently enrolled trainees, faculty, and staff of KUTRRH. Access shall be done by logging in with the KUTRRH trainees, faculty, and staff username and password.
5. Off-premise internet authentication and access to library resources shall be done through EZProxy.
6. Off-premise access to KUTRRH restricted ICT infrastructure, systems and services including the HMIS shall be done through VPN (Virtual Private Network) and only on appropriately secured computing device.
7. Access to restricted ICT infrastructure, systems, and services from KUTRRH premises shall be through VPN subject to perimeter security (firewall) and access rights for the respective authorized staff.
8. Patients, trainees, faculty, and staff shall be allowed off-premise access to all services available through the staff portal and the trainee portal and health app.
9. KUTRRH reserves the right of authorization for off-premise access to any electronic resource.

6.4.3 Access Rights

6.4.3.1 Rights Matrix

An access rights matrix shall be developed with respect to job roles and responsibilities. It shall be the basis for the user access right configuration on engagement, transfer, or reassignment.

6.4.3.2 Assignment of Rights

Assignment of Rights shall be guided by the Access Right Matrix. It will depend on individual role in the system. The allocation of rights shall be done by the Systems Super Administrator.

6.4.4 Passwords

Where technically feasible all ICT infrastructure, systems and services must be protected using strong passwords. All passwords created for use in KUTRRH must meet the requirements of this policy. The ICT Department reserves the right to monitor and audit all password use in KUTRRH to ensure compliance with this policy and to identify any weak passwords that could compromise safety and security.

All passwords must be unique and meet the following standard:

1. Password Length:

- a. All passwords **MUST BE** a minimum of 8 characters in length.
- b. If existing systems are not capable of supporting 8 characters, then the maximum number of characters allowed within the system must be used.
- c. Passwords must not be left blank.

2. Password Complexity:

- d. Passwords **MUST CONTAIN** a combination of letters (both upper & lower case), numbers (0-9) and at least one special character (for example: “, £, \$, %, ^, &, *, @, #, ?, !, €).

3. Passwords or part of a password **MUST NOT CONTAIN**:

- e. Any word(s) found in an English or foreign language dictionary. Any word(s) spelled backwards (e.g. random, mondar).
- f. Any word with numbers appended (e.g., Cherry2018); any common keyboard sequences (e.g., qwerty).
- g. Any names of people, places, or organizations - (e.g., Rusinga, Nairobi18, MumiasSugar).
- h. Any personal information related to a user (e.g., user name, address, date of birth, personnel no., car registration number, telephone number).
- i. A sequence of consecutive numbers or letters (e.g., 12345678, abcdefgh, abcd1234).

4. Password history and aging:

- a. No password may be re-used by a user within a 6-month period.
- b. User-level passwords such as those used to access the HMIS, computer devices, information systems and network domains must be changed at least every 90 days.
- c. System-level passwords such as those used by super administrators, database administrators, system administrators and network administrators must be changed at least every 60 days.
- d. Systems will be configured to provide notifications upon password expiry.

5. Password security:

- a. Users should avoid using the same password for multiple system or purposes.
- b. Each user is responsible for all activities performed on the HMIS, any device, information system or application while logged in under their individual access account and password.
- c. Except for generic group access accounts users must only use user access accounts and passwords which have been assigned to them.

- d. Users must ensure all passwords except those used for generic/group access accounts are always kept confidential and are not shared with others including their co-workers or third parties.
- e. Users must not write down their password(s) on or near their computer device. However, in exceptional circumstances where a password must be written down, the password must be stored in a secure locked place, which is not easily accessible to others.
- f. Users must not send their passwords within email messages unless the email message is encrypted.
- g. Users must change their passwords at least every 90 days or when instructed.
- h. Users who suspect their password is known by others must change their password immediately.
- i. Users must not misuse their own or another user's password and knowingly elevate their information system access account or network domain access privileges above those that they have been authorized to use.
- j. User must ensure all default passwords which are supplied by a vendor for new devices and systems are changed at installation time.

6.4.5 Responsibility

6.4.5.1 Users

1. Protecting the privacy and confidentiality of the information systems and network they access, and the information processed by those systems or networks;
2. Ensuring they only use user access accounts and passwords which have been assigned to them;
3. Ensuring all passwords assigned to them are always kept confidential and not shared with others including their co-workers or third parties;
4. Changing their passwords when due as per this Policy or when instructed to do so by designated officers of the ICT Department;
5. Complying with instructions issued by designated user managers and/or the ICT Department on behalf of KUTRRH;
6. Reporting all misuse and breaches.

6.4.5.2 User Managers

1. Ensuring that all KUTRRH employees or contractors who report to them are made aware of and are instructed to comply with this policy and all other relevant KUTRRH policies;
2. Consulting with the Human Resource Manager in relation to the appropriate procedures to follow when a breach of this policy has occurred.
3. Communicating with the ICT Department on all staff changes in the case of new staff, contractors or guests for granting of the necessary access rights or in the case of existing staff and contractors any changes in job roles and access rights (transfers, re-designations...).

6.4.5.3 ICT Department

1. Overall custodianship of all ICT infrastructure, systems and services;
2. Ensuring all passwords generated for new user accounts and password resets meet the requirements of this policy;
3. Notifying users of their passwords in a secure and confidential manner;
4. Ensuring that all ICT infrastructure, systems, applications, and services they acquired/ developed and/or deployed in KUTRRH are capable of implementing, supporting, and enforcing this policy in full.

6.5 Cryptographic Technology

6.5.1 General

1. Where possible all confidential and restricted information must be stored on a secure KUTRRH network server with restricted access. Where it has been deemed necessary approval must be sought from the Chief Executive Officer to store confidential or restricted information on any device other than a KUTRRH network server the information must be encrypted.
2. All confidential and restricted information transmitted via email to an email address outside of the KUTRRH domain (i.e., one that does not end in “@kutrrh.go.ke”) must be encrypted.
3. All passwords used as part of the process to encrypt/decrypt information must meet the requirements of the KUTRRH Password Requirements.

6.5.2 Servers

Confidential and restricted information stored on shared KUTRRH network servers which are situated in physically insecure locations (for example remote file/print servers) must be protected using strict access controls and encryption software.

6.5.3 Desktop Computers

The preferred method of encryption for KUTRRH desktop computer devices is whole disk encryption. The following types of KUTRRH desktop computers will need to have encryption software installed:

1. Desktop computers which for any reasons need to permanently store KUTRRH confidential or restricted information locally on the computer’s hard drive.
2. Desktop computers which for business, geographic or technical reasons need to permanently host KUTRRH information systems (for example, MS Access, Excel etc.) that process KUTRRH confidential or restricted information locally on the computer’s hard drive.
3. Desktop computers used by KUTRRH staff to work from home (home working).
4. Desktop computers that are in unrestricted areas, which are open to the public (for example, reception desks etc.).
5. Desktop computers that are in third party facilities.

6.5.4 Laptop, Mobile Computer & Smart Devices

6. All KUTRRH laptop computer devices must have KUTRRH approved encryption software installed prior to their use within the KUTRRH. In addition to encryption software the laptop

must be password protected and have up to date anti-virus software installed.

7. KUTRRH mobile computer devices and smart devices must have device encryption enabled or KUTRRH approved encryption software installed prior to their use within the KUTRRH.
8. The preferred method of encryption for laptop computers, mobile computer devices and smart devices is whole disk encryption. Mobile computer devices and smart devices which are not capable of whole disk encryption must use file/folder level encryption to encrypt all confidential and restricted information stored on the device.
9. Laptop, mobile computer devices and smart devices must not be used for the long-term storage of confidential and restricted information.

6.5.5 Removable Storage Devices

1. Where removable storage must be used for confidential and restricted information stored on removable storage devices must be encrypted.
2. In addition to being encrypted, removable storage devices must be stored in a locked cabinet or drawer when not in use.
3. Removable storage devices except those used for backup purposes must not be used for the long-term storage of confidential and restricted information.
4. The preferred method of encryption for removable storage devices is whole disk/device encryption. Where whole disk encryption is not possible, then file/folder level encryption must be used to encrypt all confidential and restricted information stored on the removal storage device.

6.5.6 USB Memory Sticks

1. Where confidential and restricted information must be stored in USB memory may only be stored on KUTRRH approved encrypted USB memory sticks to be availed through the ICT Department.
2. The storage of confidential or restricted information on any other USB memory sticks (encrypted or otherwise) will be considered a breach of this policy.
3. KUTRRH approved USB memory sticks must only be used on an exceptional basis where it is essential to store or temporarily transfer confidential or restricted information. They must not be used for the long-term storage of confidential or restricted information.

6.5.7 Transmission Security

1. All confidential or restricted information transmitted through email to an email address outside of the KUTRRH domain (i.e., one that does not end in “@kutrrh.go.ke”) must be encrypted. The transfer of such information outside of the KUTRRH domain must be authorized by the Chief Executive Officer. The authorization must be issued in advance of the first instance and will apply thereafter if necessary.
2. Where confidential and restricted information is transmitted through a public network (for example the internet) to an external third party the information must be encrypted first or sent via a secure channel (for example: Secure FTP, TLS, VPN etc.). The transfer must be authorized by the Chief Executive Officer. The authorization must be issued in advance of the first instance and will apply thereafter if necessary.

3. All confidential and restricted information transmitted around existing wireless networks must be encrypted using WEP (Wired Equivalent Privacy) or better. All new wireless networks installations must be encrypted using WPA (Wi-Fi Protected Access) or better.

6.5.8 Responsibilities

1. ICT Department: The ICT Department is responsible for:
 - a. The selection and requisition of all encryption facilities used within the KUTRRH.
 - b. The provision, deployment, and management of encryption facilities within the KUTRRH.
 - c. The provision of training, advice, and guidance on the use of encryption facilities in KUTRRH.
2. User Managers: User Managers are responsible for:
 - a. Ensuring that all KUTRRH employees who report to them are made aware of and are instructed to comply with this policy and all other relevant KUTRRH policies.
 - b. Consulting with the HR Directorate in relation to the appropriate procedures to follow when a breach of this policy has occurred.
3. Users: Users are responsible for:
 - a. Respecting and protecting the privacy and confidentiality of the information they process at all times.
 - b. Complying with instructions issued by the ICT Department on behalf of the KUTRRH.
 - c. Ensuring all encryption passwords assigned to them are kept confidential at all times and not shared with others.
 - d. Ensuring encryption passwords used to access encrypted devices are not written down on the encrypted device or stored with or near the encrypted device.
 - e. Reporting all misuse and breaches of this policy to their line manager.

6.6 Physical Security of KUTRRH's Sites and Equipment

6.6.1 General Physical Security

- a. Whenever possible, doors and entrance locations of facilities shall be locked when unattended and protected during non-business hours by electronic alarms.
- b. A record of the users of physical access controls such as facility keys shall be kept.
- c. A record of security related repairs and modifications, such as hardware, walls, doors, and locks, to a facility containing protected data/information shall be kept.
- d. Private desk drawers, personal computers, peripherals, and related equipment shall be locked when not in use.
- e. Back-up media shall be located off-site to avoid damage from a disaster on the premise.
- f. Protection must be implemented against fire, flood, and other environmental factors that could damage the resources.
- g. Access to/use of publicly accessible jacks shall be restricted.
- h. Emergency power shutdown controls will be installed.
- i. Equipment is to be located on racks raised above floor level.
- j. Annual testing will be performed on all fire and protective systems.

- k. Environmental controls will be implemented to ensure that temperature and humidity are maintained within limits for the equipment contained therein.
- l. Electrical power for servers hosting enterprise and departmental services must be protected by uninterruptible power supplies (UPS) to ensure continuity of services during power outages and to protect equipment from damage due to power irregularities. Each UPS should have sufficient capacity to provide at least 15 minutes of uptime to the systems connected to it.
- m. Automatically switched-on generator to last at least 12 hours shall be provided for critical ICT infrastructure.
- n. All network information technology resources must be fitted with effective Surge Protectors to prevent power spikes and subsequent damage to data and Hardware.
- o. Secured access devices (e.g., access cards, keys, combinations, etc.) must not be shared with or loaned to others by authorized users.

6.6.2 Data Center/Nerve Center/Server/Equipment Rooms

The following specific requirements shall apply to the Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces:

- a. Comply with all the general physical security requirements listed above.
- b. The Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces shall be in a secure environment protected by keys or card or biometric access controls to mitigate unauthorized access and use.
- c. The Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces access shall be restricted to only authorized personnel and authorized third parties when escorted/supervised.
- d. Fire suppression equipment shall be installed within the Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces.
- e. Clear signs shall be placed at the entrance to the Data Center, Nerve Center, Server and ICT Equipment Rooms/Spaces, warning that access is restricted to authorized personnel and prohibiting food, drink, and smoking.
- f. The Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces shall not double as office space or storage space or any other shared purpose.
- g. The Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces should not have windows through which a person could gain access. If there are windows, they should be bulletproof/shatterproof, and/or protected by metal grates to prevent access if broken.
- h. The Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces shall be monitored by CCTV or IP cameras 24/7.
- i. The Data Center, Nerve Center, Server, and ICT Equipment Rooms/Spaces shall have redundant power sources, such as a generator, to power electronic locks and authentication systems in case of a power failure or outage.
- j. A complete inventory of Data Center, Nerve Center, Server and ICT Equipment Rooms/Spaces and network equipment, including brands, models, serial numbers, and physical descriptions, should be completed, and kept up to date.

- k. A system for securely disposing of unwanted discs, tapes, cards, hard drives, printed paper, and anything else that could contain confidential information shall be implemented.

6.7 Operational Security

All KUTRRH, patients and relatives, trainees, staff, contractors, and third-party personnel are responsible for:

1. being aware of and complying with KUTRRH-wide and internal policies and their responsibilities for protecting ICT infrastructure, systems, and services in their Department and Section;
2. using information resources only for intended purposes as defined by procedures, statutes, and policies of KUTRRH as well as laws, and regulations governing the area of operations; and
3. being accountable for their actions relating to their use of all KUTRRH ICT infrastructure, systems, and services.

6.8 Secure Communications and Data Transfer

6.8.1 Use of Email Address

KUTRRH staff and authorized third parties should be aware of the following issues regarding electronic communications:

1. Employees may use or distribute a work-related email or other electronically stored information only as is appropriate in the performance of the employee's work responsibilities.
2. KUTRRH Email should not be used for commercial or political purposes.
3. KUTRRH Email should not be used for fundraising activities not endorsed by KUTRRH.
4. All KUTRRH Email users are expected to read all official messages sent to their KUTRRH Email address and/or forwarded from their KUTRRH Email address to another email address and will be presumed to have done so in a timely manner. The KUTRRH Email system is an official means of communication. KUTRRH views communication via email to constitute being duly informed for patients, staff, and trainees.
5. The KUTRRH Email system is a delivery system for communication and does not constitute a long-term storage system for documents delivered by email. Therefore, the email system ought not to be relied upon for the long-term retention of official records of KUTRRH. KUTRRH provides storage systems outside of the email system for long-term retention such as the network storage drive.
6. Users of the KUTRRH Email system do not have a right of privacy in communications transmitted or stored on KUTRRH information technology resources. Thus, KUTRRH Email address should not be used to send or receive personal email that a KUTRRH staff or other party employee wants to keep private.
7. Emails are written records that could be subject to review with just cause. Email records and

information in electronic form on central computers can be subpoenaed. Messages that the user has deleted may still exist on system's backup media for weeks or months.

8. Certain types of email and uses of email or other forms of electronic communications are prohibited; these include chain letters, obscene messages, harassing messages, and unsolicited political messages. Email that violates any KUTRRH policy or is otherwise used for an illegal purpose is prohibited.
9. All email sent through KUTRRH's systems and network must accurately show from whom the email originated. Do not alter email headers to maliciously conceal or misrepresent the source of a message.
10. KUTRRH may employ automated systems to reduce the amount of unwanted "junk" mail. It is known that this may on occasion reject a valid email.
11. Dynamic Host Configuration Protocol (DHCP) and Internet Protocol (IP) logs are retained for one week.
12. The limit for an attachment in KUTRRH Email is 25MB. Where technology and resources allows, this may be increased.
13. Anyone who has a communication intended for distribution to the entire KUTRRH community requires the approval and review of a Communications Officer or Deputy Director, ICT & Innovation, or the respective Directors.

6.8.2 Voicemail Use

The voicemail system should be used appropriately, efficiently in an ethical and lawful manner, consistent with KUTRRH policies. Guidelines surrounding use of voicemail follow general rules of common sense and common courtesy, and include the following:

1. Respect the privacy of others.
2. KUTRRH voicemail system may not be used to defame, harass, intimidate, or threaten any other person(s), or to send unnecessarily repetitive messages.
3. KUTRRH voicemail may not be used to publish, post, transmit, or otherwise make available content that is copyrighted, obscene, or legally objectionable.
4. Voicemail passwords and access to mailboxes should not be shared. Each individual is responsible for their own account.
5. Do not forge or otherwise misrepresent your personal identity. This policy does not prohibit users from engaging in anonymous communications, providing that such communications do not otherwise violate one of the above stated policies.

6.8.3 Access to Individual Email

KUTRRH has the right and ability to access individual @kutrrh.go.ke email accounts, even though a user has established personal login credentials. However, KUTRRH and its agents or custodians of the email system will not access or disclose the content of an individual's email account unless KUTRRH has a good faith belief that the terms of acceptable use have been violated. In addition to a good faith belief of a violation, permission must be secured from the

Chief Executive Officer or the designated authority.

Although not a complete list, the following conditions represent potential situations for access:

1. Suspected violation of the law, regulation, or KUTRRH policy.
2. Enforceable governmental request, a subpoena, or legal request to which KUTRRH is required to respond.
3. Suspected criminal conduct or to protect against harm to the rights, property, or safety of KUTRRH, its employees, or the public.
4. When information is necessary to conduct KUTRRH business and the user of the account is unavailable.
5. When information is necessary to conduct KUTRRH business and the user is no longer employed by KUTRRH.
6. A health or safety emergency.

Although not a complete list, the following conditions represent unacceptable access to an individual's email account:

1. For any reason other than a suspected violation of the terms of acceptable use, or a safety or an emergency.
2. Curiosity.
3. Permission from the Chief Executive Officer is not requested or is not given.
4. To bypass engaging an individual in conversation when that individual is available and there is not sufficient evidence to suggest an emergency.

6.8.4 Data Transfer

1. Secure protocols will always be used in preference over unsecured protocols for data transmission. If no secured protocol is available, then a secured tunneling (IPSec or SSL VPN) technique must be utilized to prevent information being transmitted in plain sight of network users.
2. When engaging with third party suppliers of service, data transfer between the relevant parties should be conducted with both a secured tunnel serving secured data wherever possible.
3. Where it is impossible to implement the secure tunneling of data (as presented above), transmission of data must still be secured and the target system must be completely isolated, in terms of an appropriate technology (such as VLAN segregation) from connectivity to the main KUTRRH network.
4. Inbound and outbound traffic will be restricted to either a single IP or an address pool and specific ports must be opened solely for legitimate communications to take place.
5. The security of data transmission and penetration to detect possible leakage must be tested at regular intervals to ensure satisfactory operation; these tests must be scheduled and communicated with KUTRRH Community in advance to ensure business continuity.

6.8.5 Sender's Responsibility

It is the sender's responsibility to assess the risk of what they intend to do and ensure that all associated risks are adequately understood and covered, and that the transfer is properly authorized.

6.9 Secure Acquisition, Development, and Support of Information Infrastructure

6.9.1 Hardware

1. All hardware is the property of the KUTRRH.
2. ICT hardware shall not be removed from KUTRRH premises without written permission from the Deputy Director, ICT & Innovations.
3. Exceptions apply for portable devices where written permission has already been granted by relevant offices/officers and private ICT hardware. If an officer leaves the organization all devices and peripherals are to be returned to KUTRRH.
4. Equipment acquired through processes other than normal procurement must be inspected and approved by the ICT for compatibility during the acquisition process. Notification to the ICT must be made upon delivery to facilitate the addition of the equipment to the ICT asset register.
5. All procurement of KUTRRH hardware shall be in accordance with the Public Procurement and Asset Disposal laws and regulations.
6. The procurement shall be centralized within the ICT Department to ensure conformity to KUTRRH hardware and any associated software standards as well as planning and budgeting.
7. All requests, upon review of the need and determination of specifications with the user department shall be submitted by the Deputy Director, ICT & Innovation. The Deputy Director, ICT & Innovation may consider the availability of funds, existence of other alternatives and the strategic interests of KUTRRH.
8. All hardware donations to KUTRRH from any source are subject to checks by the ICT Department for suitability and fit-for-purpose and to ensure equity in use/distribution.
9. The ICT Department shall ensure all ICT assets are maintained in accordance with the manufacturer's instructions and with any documented internal procedures to ensure it remains in good working order. Employees involved with equipment maintenance should:
 - a. Retain all copies of manufacturer's instructions.
 - b. Identify recommended service intervals and specifications.
 - c. Enable a call-out process in the event of failure.
 - d. Ensure only authorized technicians complete any work on the equipment.
 - e. Record details of all remedial work carried out.

- f. Identify insurance requirements and put the necessary cover.
- g. Record details of faults occurrence and remedial actions required. A service history record of equipment shall be maintained so that as equipment becomes older, decisions can be made regarding the appropriate time for it to be replaced.

- 10. The ICT Department reserves the right to declare obsolescence.
- 11. Any unserviceable, obsolete, or surplus hardware will be disposed in accordance with various methods provided by the Public Procurement and Asset Disposal laws and regulations. The reserve price shall be set at residual value of the equipment.
- 12. Software and data in all equipment that is to be reused, disposed of, or returned upon expiry of leasing period must be erased or destroyed using professional procedures and tools to ensure total removal.

6.9.2 Software

- 1. All software's are the property of KUTRRH.
- 2. Employees are prohibited from downloading and installing any software on KUTRRH hardware or changing the configuration without reference to the ICT Department.
- 3. All software installed by the ICT Department must be appropriately licensed.
- 4. The ICT Department must ensure that all software is regularly and timely upgraded/updated.
- 5. Employees are prohibited from making copies of any KUTRRH owned software programs.
- 6. All procurement of KUTRRH software shall be in accordance with the Public Procurement and Asset Disposal laws and regulations. The procurement shall be centralized within the ICT Department to ensure conformity to KUTRRH software standards as well as planning and budgeting.
- 7. All requests, upon review of the need and determination of specifications with the user department shall be submitted by the Deputy Director, ICT & Innovation. The Deputy Director, ICT & Innovation may consider the availability of funds, existence of other alternatives and the strategic interests of KUTRRH.
- 8. All software donations to KUTRRH from any source are subject to check by the ICT Department for suitability and fitness-for-purpose and ensure equity in distribution.
- 9. The Deputy Director, ICT & Innovation shall advise Management and the Board of KUTRRH on the decommissioning of obsolete, outdated or no-longer supported software.
- 10. The ICT Department is exclusively responsible for installing and supporting all acquired software on KUTRRH hardware.

6.10 Security for Suppliers and Third Parties

- 1. All third-party service providers to KUTRRH, collaborators and partners (with whom KUTRRH has contracts/agreements, memoranda of understanding/agreement/finance or partnerships) must agree to always follow KUTRRH's security management systems.
- 2. All KUTRRH contracts/agreements, memoranda of understanding/agreement/finance, partnership with third parties must defined in scope and boundaries of undertakings to ensure

protection of KUTRRH information assets and third-party security.

3. KUTRRH staff must assess the risk that ICT assets may be exposed to by the third parties.
4. All contracts/agreements, memoranda of understanding/agreement/finance or partnerships must be monitored and reviewed to ensure adherence to information security requirements.
5. All KUTRRH assets, to which a third party has access or wishes to have access must be handled in accordance with procedures that satisfy legal, regulatory and risk and security management.
6. Where evidence of compliance to the legal, regulatory and risk and security management is not evidenced or ascertained on the third parties, KUTRRH may employ background checks, audits, and other mechanisms for the protection of KUTRRH information assets.
7. Where the contracts/agreements, memoranda of understanding/agreement/finance or partnerships include data sharing there shall be non-disclosure agreements/clauses.
8. All assets created, used, accessed, processed, managed, or stored by the third parties, which are considered KUTRRH property must be securely transferred to KUTRRH and securely removed from non-KUTRRH media.
9. Should the third party encounter any risks or threats that may impact the confidentiality, integrity, and availability of KUTRRH assets they must inform KUTRRH within a reasonable timeframe to enable KUTRRH to take the necessary remedial action. This may be reported through the Call/Contact Center toll free line: 1558 or email: customer care@kutrrh.go.ke.

6.11 Incident Management

1. Incidents shall be reported promptly and responded to in a quick, effective, and orderly manner to reduce the negative effect of incidents, to repair damage and to inform policy and mitigate future risks. These incidents include:
 - a. Presence of unauthorized personnel in sensitive areas/buildings.
 - b. Secure or sensitive storage areas found unsecured (includes delivery points)
 - c. Theft or physical loss of KUTRRH information assets (electronic/non-electronic information assets) known to have sensitive information associated (e.g., laptops/mobile phones).
 - d. Loss of storage media (removable drive, CD, DVD, flash drive,).
 - e. A server known to hold sensitive data which has been accessed or otherwise compromised by an unauthorized entity.
 - f. Suspicious or foreign hardware connected to KUTRRH's data network.
 - g. An outside entity which is subjected to attacks originating from within KUTRRH's data network.
 - h. An unauthorized or unwarranted entity causing a network outage.
 - i. System slowdown or failure.
 - j. Changes in default or user-defined settings.
 - k. Unexplained or unexpected use of system resources.
 - l. Unusual activities appearing in system or audit logs.
 - m. Changes to or appearance of new system files.
 - n. Users unexpectedly locked out.

- o. Appliance or equipment failure.
 - p. Unexpected enabling or activation of services or ports.
 - q. Unexpected activity that has been detected by KUTRRH's security defenses. This might include unusual patterns of attack detected by KUTRRH firewall.
2. All incidents shall be reported promptly to the Call/Contact Center toll free line: 1558 or email: customercare@kutrrh.go.ke.
 3. Key information about serious information security incidents, including the impact of the incident (financial or otherwise), shall be formally recorded and the records shall be analyzed to assess the effectiveness of information security controls.
 4. New risks identified because of an incident and shall be assigned to the relevant risk owner and unacceptable risks shall be mitigated promptly in accordance with KUTRRH's risk management processes.
 5. Relevant staff shall be trained in digital evidence collection, retention, and presentation, in accordance with legislative or regulatory obligations.
 6. Serious incidents shall be reported to the appropriate external authorities where relevant by authorized individuals.
 7. Contractors using KUTRRH's information systems and services shall be required to note and report any significant information security weaknesses in those systems or services.

6.12 Business Continuity/Disaster Recovery

6.12.1 Scope

All KUTRRH key business processes (patient, financial, procurement, human resource, hospital, research and innovation, portals, and communication) and key ICT infrastructure (data center, local area network, backbone, core equipment, wide area network, VPN, perimeter security, host-to-host banking) wherever managed, must comply with the requirements for business continuity and disaster recovery.

6.12.2 Objectives

The objectives of business continuity and disaster recovery policy are:

1. Recovery Time Objectives: to reduce the duration of time and a service level within which a business process must be restored after a disaster or disruption to avoid unacceptable consequences associated with a break in business continuity.
2. Recovery Point Objectives: to reduce the maximum tolerable period during which data might be lost.

6.12.3 Responsibilities

1. Audit and Risk Committee of the Board of Directors: The Audit and Risk Committee of the Board of Directors will ensure appropriate structures are in place to implement effective business continuity and disaster recovery arrangements; monitor the implementation of this policy; and raise issues of resource necessary for the adequate control of severe business continuity and disaster recovery risks.
2. Planning, Testing, and Program Maintenance

- a. Business Continuity/Disaster Recovery (BC/DR) Steering Committee:
 - i. Provides guidance and oversight for the BC/DR Program
 - ii. Provides input and approval of project objectives, scope, and timeframes
 - iii. Assists in the definition of BC/DR roles and responsibilities
 - iv. Provides support and resources for BC/DR projects and the BC/DR Manager
 - v. Provides high-level coordination and support during BC/DR plan development
 - vi. The membership of the BC/DR Steering Committee includes the Chief Executive Officer, the Chief Security Officer, Director (Corporate Affairs and Administration), Director (Clinical), Director (Nursing), Director (Finance), the Deputy Director, ICT & Innovation, Risk Officer, and the Corporation Secretary.
- b. Business Continuity/Disaster Recovery Planning Team:
 - i. Provides support to BC/DR projects and external state organizations as required.
 - ii. Individuals provide subject matter expertise from their functional areas.
 - iii. throughout the development, implementation, and maintenance of the BC/DR program.
 - iv. Develops BC/DR program guidelines, methodologies, standards, and best practices.
 - v. Ensures all BC/DR planning activity adhere to policies, procedures, and standards.
 - vi. The membership of the BC/DR Planning Team includes Deputy Director (Corporate Affairs and Administration), Deputy Director (Clinical), Deputy Director (Nursing), the Deputy Director, ICT & Innovation, the Chief Security Officer, Risk Officer, the Chief Finance Officer, and the Corporation Secretary.
- 3. Declaration of a Disaster or Emergency Response
 - a. Crisis Management Team (CMT):
 - i. Overall responsible for managing the crisis response.
 - ii. Gathers facts and analyzes conditions regarding the crisis.
 - iii. Allocates internal resources.
 - iv. Coordinates with external agencies for required resources.
 - v. Coordinates disaster response with external agencies.
 - vi. Develops and controls communication plans and official external communications.
 - vii. Manages and directs Disaster Recovery Team(s).
 - viii. The membership of the Crisis Management Team includes the Chief Executive Officer, the Chief Security Officer, Director (Corporate Affairs and Administration), Director (Clinical), Director (Nursing), Director (Finance), the Deputy Director, ICT & Innovation, Risk Officer, Communications Officer, and the Corporation Secretary.
 - b. Disaster Recovery Team(s) (DRT):
 - i. Responds to a disaster at the direction of the CMT.
 - ii. Maintains proficiency in BC/DR related procedures within their specialty areas.
 - iii. Conducts damage assessments and documents/reports findings to CMT.
 - iv. Provides for stabilization and resumption of operations after a disaster.
 - v. The membership of the Disaster Recovery Team includes the Chief Executive Officer, the Chief Security Officer, Director (Corporate Affairs and Administration), Director (Clinical), Director

(Nursing), Director (Finance), Deputy Director, ICT & Innovation, Risk Officer, Corporation Secretary, Heads of ICT Infrastructure/Applications/Security/Web & Content.

6.12.4 Restoration Priority Order

In the event of a disaster, the following is the restoration priority order:

1. Essential communications.
2. Patient, staff and third-party personnel safety and health.
3. Critical operational data (patient, financial, procurement, human resource, hospital), processes and services.
4. Patient and staff services.
5. Research and innovation data.
6. Core infrastructure (LAN, WAN, VPN, structure, and buildings).

6.12.5 Risk Management

1. KUTRRH shall maintain a low-risk appetite for the unauthorized access, disclosure, modification and/or destruction of its information assets.
2. The ICT Department in collaboration with KUTRRH Risk Office, the Internal Audit and the Security Office shall identify, analyze, mitigate, document and monitor risks related to the ICT infrastructure, systems, services, and standards.
3. KUTRRH Board and Management shall allocate resources necessary to implement appropriate controls.
4. The Internal Audit shall carry out regular audits on business continuity and disaster recovery planning, testing and recovery.
5. The Head of ICT Security Management shall be responsible for monitoring and reporting on risks, threats, vulnerabilities, penetration testing and preparedness for BC/DR operations.
6. The Deputy Director, ICT & Innovation shall be responsible for the management of the BC/DR controls.

6.12.6 Risk Mitigation

1. Appropriate controls shall be implemented with respect to risks to business continuity and disaster recovery.
2. Redundancy shall be implemented for core ICT infrastructure, systems, services, and standards including:
 - a. Data Center at KUTRRH Main Premise and hot-site Data Center with the Kenya Education Network. An alternate data center may be established at an approved location.
 - b. Main Fiber Cable and Dark Fiber with the Kenya Education Network.
 - c. Main fiber backbone within branches/annexes and redundant fiber backbone for strategic buildings and service areas.
 - d. Star network across KUTRRH premises (failure of one building/annex does not affect all buildings/annexes).
 - e. Redundant core devices: core switch, firewalls, servers, cooling, CCTV, access control

systems.

- f. Redundant power systems: ordinary supply, network UPS, generators.
- g. Twinning of key ICT Human Resource (Network Administrators, Database Administrators, Systems Administrators, and Information Security Specialists).
- h. Insurance of key of information assets.

6.13 Compliance

The Objective of Compliance is to avoid breaches of legal, statutory, regulatory, or contractual obligations related to information security.

The provisions of this policy apply to all KUTRRH's patients and staff (including temporary/ piece-rate/ casual laborers and staff engaged under contract) as well as third parties. This policy includes, but is not limited to-

- a. KUTRRH information in any form, including print, electronic, audio, video, and backup and archived data. This includes, computer systems, peripheral devices, software applications, databases, middleware, and operating systems.
- b. Physical premises occupied by the personnel and equipment;
- c. Operational environments including power supply and related equipment;
- d. Processes and procedures; and
- e. Transmission of Communications and related pathways.

6.14 E-Waste Management

- 2. KUTRRH endeavors to minimize e-waste generation. To mobilize and sensitize stakeholders on the proper management and handling of e-waste on a sustainable basis, to develop and implement a critical human resource base knowledgeable in handling e-waste, to develop and champion beneficial environmentally sound e-waste recycling and to provide guidance on the standards of electronic equipment that is imported into KUTRRH.
- 3. The ICT Department shall:
 - a. In liaison with the respective Directorate, Department or Section, identify e-waste in KUTRRH.
 - b. Ensure that e-waste is collected quarterly and kept in an appropriate storage pending the recommendations/approval of recommendations of the Disposal Committee.
 - c. Profile all e-waste generated at least once every quarter and prepare a report to the Disposal Committee including recommendations for disposal.
 - d. Execute the recommendations of the Disposal Committee in liaison with the Procurement Department and prepare a report for KUTRRH Management Board.
 - e. Organize quarterly awareness forums for sensitization of patients, staff, and partners on e-waste management.
 - f. Organize quarterly voluntary surrender of e-waste for safe disposal and management.
- 4. KUTRRH will facilitate research and development to carry out specific research to evolve cost effective technologies and effective adaptation of the best available technologies for e-waste

management.

5. KUTRRH will facilitate development of skills among staff and partners as needed for effective and efficient implementation of e-waste management operations within and out of KUTRRH.

6.15 Telemedicine

6.15.1 Guiding Principles

The practice of telemedicine in KUTRRH shall be guided by the following core principles:

1. Practices implemented will ensure quality patient-centered care.
2. Communication methods utilized will be secure and effective.
3. Treatment options recommended will be appropriate and practical.
4. Implementation will ensure patient feedback and patient satisfaction.

6.15.2 Scope

1. KUTRRH may utilize telemedicine, the use of medical information exchanged from one site to another via electronic communications, to provide quality patient-centred care. This includes for the purpose of Home-Based Care, collaboration with partner hospitals, Multi-Disciplinary Teams (MDT) or Continuous Medical Education Sessions (CME).
2. The scope of the KUTRRH telemedicine policy covers the licensure; establishment of the physician-patient relationship; evaluation and treatment; informed consent; continuity of care; referrals for emergency services; medical records; privacy and security of the patient records and exchange of information; disclosures and functionality of online services; and prescribing.
3. The scope shall also cover physician-physician/facility-facility telemedicine operations subject to the existence of an agreement between KUTRRH and the partner facility.
4. Existence of an agreement may not be required for physician-physician telemedicine operations in the case of Multi-Disciplinary Teams (MDT) or Continuous Medical Education Sessions (CME).

6.15.3 Purpose

The purpose of the telemedicine policy is to ensure patient-safety and privacy of health information, and fulfill the broader commitments for confidentiality, integrity, availability, and auditability as the per the Hospital information security management system.

6.15.4 Responsibility

1. It is the responsibility of the respective Head of Department to ensure that the licensure; establishment of the physician-patient relationship; evaluation and treatment; informed consent; continuity of care; referrals for emergency services; medical records; privacy and security of the patient records and exchange of information; disclosures and functionality of online services; and prescribing adhere to Hospital policies.

2. In the case of a partner facility the respective partner facility to ensure that the licensure; establishment of the physician-patient relationship; evaluation and treatment; informed consent; continuity of care; referrals for emergency services; medical records; privacy and security of the patient records and exchange of information; disclosures and functionality of online services; and prescribing adhere to Hospital policies.
3. In the case of Multi-Disciplinary Teams (MDT) or Continuous Medical Education Sessions (CME), the host institution/physician shall be responsible for the licensure; establishment of the physician-patient relationship; evaluation and treatment; informed consent; continuity of care; referrals for emergency services; medical records; privacy and security of the patient records and exchange of information; disclosures and functionality of online services; and prescribing adhere to Hospital policies.

6.15.5 Licensure

1. The healthcare workers involved in every instance of telemedicine shall be qualified and have a valid license.
2. The Document Verification Office shall review the documents of the healthcare workers prior to the telemedicine sessions and advise the respective HODs.
3. Interns, students, and support staff shall be subject to confidentiality and non-disclosure agreements of the host institution prior to the telemedicine sessions.

6.15.6 Establishing the Relationship

6.15.6.1 Physician-Patient Relationship

A physician-patient relationship shall be deemed to be established once the physician agrees to diagnose and treat the patient, and the patient agrees to be treated, whether or not an in-person encounter has occurred between the physician (or any other appropriately supervised health care practitioner) and patient. The physicians take the following steps:

1. Verify the location and identity of the patient to the best extent possible.
2. Provide and validate the healthcare workers credentials to the patient, such as medical license or other clinical qualifications.
3. Disclose communication and treatment methods to patients and obtain informed patient consent where appropriate.

6.15.6.2 Physician-Physician/Facility-Facility

1. A physician-physician/facility-facility telemedicine relationship shall only apply where KUTRRH has an existing agreement with the partner facility.
2. A physician-physician/facility-facility relationship shall be deemed to be established when either KUTRRH initiates and the partner facility accepts or the vice versa.
3. The host partner facility shall be responsible for all matters concerning diagnosis, treatment, consent for telemedicine and all others matters pertaining to the patient including privacy and confidentiality.

6.15.7 Evaluation and Treatment

1. The standard of care for practicing telemedicine shall be the same as that of conventional medicine.

2. For KUTRRH patients the evaluation, diagnosis, consultation, and prescribed treatment shall be documented in the patient's medical record or electronic health record as per the KUTRRH HMIS.
3. For patients from partner facilities evaluation, diagnosis, consultation, and prescribed treatment shall be documented in the patient's medical record or electronic health record shall be documented as per the partner facilities HMIS, unless the patient has been referred to KUTRRH.
4. Where the evaluation, diagnosis or treatment is too complicated for telemedicine, a request for an in-person appointment shall be booked at KUTRRH for KUTRRH patients or referral be advised for partner facilities.

6.15.8 Continuity of Care

Follow-up care should be readily available to the patient, either from the physician conducting telemedicine or a provider designated by the physician. If the patient-physician encounters are done exclusively using telemedicine, then all documentation must be accessible to the patient. Patients may also request that the information be provided to their other healthcare providers.

6.15.9 Referrals for Emergency Services

Telemedicine patients shall be provided with information on access to emergency services where a patient requires referral to an acute care facility.

6.15.10 Fees and Charges

1. The physician-patient consultation fees shall be as per the KUTRRH fees, charges, payments methods and financing arrangements (such as NHIF).
2. Any other applicable fees shall be as per the existing agreement between KUTRRH and the partner facility.

6.15.11 Technical ICT Issues

1. Telemedicine sessions shall be planned on a case basis and evaluated for suitability of technology including the devices and applications in use, data communication and the ability of the physician, patient, or facility to use telemedicine effectively and efficiently.
2. The technical details for each telemedicine session shall be provided prior to the session providing adequate time for technical setup and testing.

7. LEADERSHIP AND GOVERNANCE FRAMEWORK

7.1 Ownership

The Chief Executive Officer is the owner of all ICT infrastructure, systems and services, people, policy, standards, and processes. The ICT Department is the custodian and the implementing agency of the strategies, plans and decisions of the Board of Directors, Chief Executive Officer, Executive Expenditure Committee, the Senior Management Team, Health Management Team, and other authorized structures of KUTTRH.

7.2 The Organizational Structure

The organizational structure of the ICT leadership and governance is guided by the critical components of a management information system of the enterprise. The critical components of management information systems and enterprise resource planning systems of KUTRRH:

hardware, networks, software (applications, ERPs, operating systems, databases), data, information, people, policy, standards, processes, services, and cybersecurity shall be managed under the ICT Department through the following departments:

1. Infrastructure and Systems Administration - hardware and networks.
2. Applications, Support and Training - software, data, information, and user training.
3. Cybersecurity and Business Continuity Management – monitoring, evaluation, preparedness on cybersecurity and business continuity.
4. Web, Media, and Digital Brand – web design, content, media and social media engagement and digital brand.
5. Digital Innovation, Policies and Standards – new digital solutions, applications, and tools; emerging frontiers (e.g., data science, artificial intelligence) and their application in healthcare, policies, and standards.

The overall leadership for the implementation of the KUTRRH ICT Policy is the Chairperson of the Board of Directors, the Chief Executive Officer, the Executive Committee, the Deputy Director, ICT & Innovation, and the Senior Management Team. The organizational structure is shown in Figure1.



www.kutrrh.go.ke | email: info@kutrrh.go.ke
General Inquiries: 1558/ 0800 721 038
P.O Box 7674 - 00100 GPO Nairobi, Kenya